

NIST CSF Incident Report Analysis

DoS Attack Response & Security Improvement Plan

Domain	Framework Used	Difficulty	Status
Network Security / Incident Response	NIST Cybersecurity Framework (CSF)	Beginner	Completed

Project Overview

This activity is part of the Google Cybersecurity Certificate curriculum. As a cybersecurity analyst at a multimedia company, I was tasked with using the National Institute of Standards and Technology (NIST) Cybersecurity Framework (CSF) to analyse a real network security incident — a Denial of Service (DoS) attack — and create a structured security improvement plan. The NIST CSF is a voluntary, scalable framework widely used across industries to manage and reduce cybersecurity risk through five core functions: Identify, Protect, Detect, Respond, and Recover.

This report demonstrates the ability to apply a recognised industry framework to a real incident, systematically analyse root causes, and develop actionable security recommendations — a core competency for cybersecurity analysts and incident responders.

Scenario

A multimedia company offering web design, graphic design, and social media marketing services to small businesses experienced a Denial of Service (DoS) attack that disrupted its internal network for two hours. A malicious actor exploited an unconfigured firewall to flood the network with ICMP echo request (ping) packets, overwhelming the network bandwidth and preventing all legitimate internal traffic from accessing any network resources. The incident management team responded by blocking ICMP packets, taking non-critical services offline, and restoring critical services. The cybersecurity team was then tasked with using the NIST CSF to analyse the incident and build a comprehensive security improvement plan to prevent recurrence.

The NIST Cybersecurity Framework

The NIST CSF consists of five core functions that provide a lifecycle approach to cybersecurity risk management:

Function	Purpose
Identify	Manage security risks through regular audits of networks, systems, devices, and access privileges to identify potential gaps
Protect	Develop and implement safeguards through policies, procedures, training, and tools that mitigate cybersecurity threats
Detect	Design and implement tools needed to detect threats and attacks, improving speed and efficiency of detections
Respond	Design action plans for containing, neutralising, and analysing security incidents; implement process improvements
Recover	Construct plans to restore affected systems to normal operation and recover systems and data affected by incidents

Incident Summary

Incident Type: ICMP Flood Denial of Service (DoS) Attack

Duration: Approximately 2 hours

Systems Affected: All internal network services and resources

Root Cause: Unconfigured firewall — no ICMP rate limiting or source IP verification

Attack Vector: External malicious actor flooding network via ICMP ping packets through the unconfigured firewall

Impact: Complete loss of internal network connectivity for all employees and services for 2 hours

The attack exploited a fundamental misconfiguration: the firewall had no rules to limit or inspect incoming ICMP traffic. This allowed the attacker to send an unrestricted flood of ICMP ping packets, consuming all available network bandwidth. Because ICMP is a Layer 3 protocol used for diagnostic purposes (ping), it should not be permitted to enter a corporate network from untrusted external sources without strict rate limiting and source validation.

NIST CSF Analysis

IDENTIFY

Attack Type: ICMP Flood Denial of Service (DoS) attack

The cybersecurity team audited the network, systems, and firewall configurations involved in the attack. The audit identified the following:

	• Root Cause: An unconfigured firewall with no ICMP rate limiting and no source IP address verification rules, leaving the network fully exposed to volumetric flooding from any external source. • Affected Systems: All internal network services and shared resources. No individual servers or user endpoints were compromised — the attack disrupted availability rather than confidentiality or integrity. • Attack Vector: The malicious actor sent ICMP echo requests (pings) from external sources through the unconfigured firewall, overwhelming the network with traffic that could not be distinguished from legitimate ICMP traffic without proper filtering rules. • Business Impact: The company was unable to serve clients or conduct internal operations for two hours, representing significant potential revenue loss and reputational risk for a company that provides digital services to small businesses.
--	--

PROTECT	To protect the organisation's assets against future ICMP-based DoS attacks and similar volumetric threats, the following protective controls have been implemented and recommended: 1. Firewall ICMP rate limiting (Implemented): A new firewall rule limits the rate of incoming ICMP packets, preventing any single source from overwhelming the network with a flood of ping requests. 2. Source IP address verification (Implemented): The firewall now validates source IP addresses on incoming ICMP packets to detect and block spoofed addresses commonly used in amplification attacks. 3. Regular firewall audits (Recommended): All firewall rules should be reviewed and audited on a scheduled basis to identify and remediate misconfigurations before they can be exploited. 4. Network segmentation review (Recommended): Network architecture should be reviewed to limit the blast radius of future attacks, ensuring a flood targeting one segment cannot impact the entire internal network. 5. Security training (Recommended): Staff responsible for firewall and network configuration must receive updated training on hardening principles, default-deny policies, and least-privilege access.
----------------	---

DETECT	To improve the organisation's ability to detect future DoS attacks and other network anomalies, the following detection capabilities have been implemented and recommended: 1. Network monitoring software (Implemented): Continuously analyses traffic patterns and alerts the security team when abnormal traffic volumes
---------------	---

	or unusual packet types are detected, such as a sudden spike in inbound ICMP traffic. 2. IDS/IPS system (Implemented): Filters and flags ICMP traffic exhibiting suspicious characteristics such as abnormally high packet rates, malformed packets, or traffic from known malicious IP ranges. 3. Firewall logging (Recommended): Comprehensive logging should be enabled to capture all inbound and outbound traffic events, providing a complete forensic record for post-incident analysis. 4. SIEM platform (Recommended): A Security Information and Event Management (SIEM) system should be considered to aggregate and correlate log data from the firewall, IDS/IPS, and network monitoring tools in a centralised dashboard, enabling faster detection and response.
--	--

RESPOND	During the incident, the team executed the following immediate response actions: • Blocked all incoming ICMP packets at the firewall to halt the attack traffic • Took all non-critical network services offline to reduce load on affected infrastructure • Restored critical services in order of business priority For future incidents, the following response procedures have been formalised: 1. Containment: Immediately isolate the affected network segment or block attack source traffic at the firewall to limit the impact. If the attack originates from multiple sources (DDoS), engage the upstream ISP for traffic scrubbing. 2. Neutralisation: Apply firewall rules to drop malicious traffic and engage the IDS/IPS to automatically filter suspicious packets. Maintain an up-to-date blocklist of known malicious IP ranges. 3. Analysis: Review firewall logs, network monitoring dashboards, and IDS/IPS alerts to determine the attack vector, source IPs, packet types, volume, and duration. Document all findings in a formal incident report. 4. Communication: Notify senior management and affected internal stakeholders. If client services are affected, notify clients promptly and comply with all applicable regulatory reporting obligations. 5. Improvement: Conduct a post-incident review (blameless retrospective) to identify remaining security gaps and update the incident response plan and firewall configuration accordingly.
----------------	--

RECOVER	Following the two-hour attack, the team restored all affected network services in order of criticality:
----------------	--

- Critical services (client-facing platforms and communications) were restored first
- Firewall logs and traffic data were reviewed to confirm the attack had fully ceased before restoring normal operations
- A post-incident configuration audit verified all new protective controls were functioning before returning to full operations

For future incidents, the recovery plan includes:

- 1. Regular configuration backups:** Maintain tested backups of all network and firewall configurations to enable rapid restoration after an incident.
- 2. Documented RTOs:** Define and document Recovery Time Objectives (RTOs) for each service tier, ensuring the team knows the target restoration time for critical vs non-critical services.
- 3. Stakeholder communications:** Establish a communication plan to keep internal stakeholders and affected clients informed throughout the recovery process with clear, timely updates.
- 4. Lessons-learned sessions:** Conduct a structured post-incident review after every significant incident to continuously improve both response and recovery procedures, and update the incident response playbook accordingly.

Security Controls Implemented

The following security controls were implemented by the network security team as a direct result of this incident:

Control	Type	Purpose
ICMP rate limiting firewall rule	Technical (Preventive)	Limits the volume of incoming ICMP packets to prevent network flooding
Source IP address verification	Technical (Preventive)	Detects and blocks packets with spoofed source IP addresses
Network monitoring software	Technical (Detective)	Continuously monitors traffic patterns for anomalies and generates alerts
IDS/IPS system	Technical (Detective/Preventive)	Filters suspicious ICMP traffic based on defined characteristics and rules

Key Takeaways

- A single firewall misconfiguration — the absence of ICMP rate limiting — was sufficient to bring down an entire organisation's network for two hours. This reinforces the principle that firewall configurations must be proactively reviewed and tested, not assumed to be correct.
- The NIST CSF provides a highly effective, structured framework for both responding to incidents and building forward-looking security improvement plans. Its five functions (Identify, Protect, Detect, Respond, Recover) map directly to the lifecycle of any security incident.
- ICMP flood attacks exploit the fact that ICMP is a trusted protocol used for network diagnostics. Unrestricted inbound ICMP traffic from external sources should always be rate-limited or blocked at the perimeter firewall in a default-deny configuration.
- Defence-in-depth is critical: no single control is sufficient. This incident required a combination of firewall rules, IDS/IPS, network monitoring, and source IP verification to adequately protect against future attacks.
- Speed of response matters in availability attacks. Clear, pre-documented response procedures (knowing which services to take offline first and in what order to restore them) significantly reduce the duration and business impact of a DoS incident.
- Post-incident reviews are not optional. Every significant incident should result in an updated incident response plan, firewall ruleset, and security posture. Security is a continuous improvement process, not a one-time configuration.

Skills Demonstrated

Analytical Skills	Security Knowledge	Professional Competencies
NIST CSF application Root cause analysis Attack vector identification Control gap analysis Risk impact assessment	DoS/DDoS attack mechanics ICMP protocol behaviour Firewall configuration principles IDS/IPS capabilities Network security architecture	Incident report writing Structured framework application Security recommendations Stakeholder communication planning Recovery planning (RTO)

Conclusion

This activity demonstrated the practical application of the NIST Cybersecurity Framework to a real-world network security incident. By systematically working through each of the five functions — Identify, Protect, Detect, Respond, and Recover — I was able to produce a comprehensive incident analysis and security improvement plan that

addresses both the immediate cause of the attack and the systemic security gaps that allowed it to succeed.

The NIST CSF is one of the most widely adopted cybersecurity frameworks globally, used by organisations of all sizes and across all sectors. The ability to apply it effectively to an incident scenario is a directly transferable skill for SOC analyst, security engineer, and cybersecurity consultant roles.